

# NovaPay Solutions Ltd.

## ISO/IEC 27001 Cybersecurity GRC Project Overview

|              |                                               |
|--------------|-----------------------------------------------|
| Prepared by  | Bola                                          |
| Organisation | NovaPay Solutions Ltd. (fictional case study) |
| Industry     | FinTech / Digital Payments                    |
| Framework    | ISO/IEC 27001:2022                            |
| Purpose      | Cybersecurity GRC portfolio project           |

*Portfolio disclaimer: NovaPay Solutions Ltd. is a fictional organisation adapted from the supplied PayNest capstone case study. No real employer, customer or production data is used.*

## 1. Project Background

NovaPay Solutions Ltd. is a growing Nigerian fintech company providing digital payment services to individuals and small businesses. The business handles customer information, transaction data, employee information, financial records, application/source code and cloud-based systems. As the organisation scales, management wants a more formal, repeatable and evidence-driven approach to information security.

The case study shows that security activities exist, but governance has not matured at the same pace as the business. The confirmed issues include an undefined ISMS scope, incomplete policies, no formal asset inventory, inconsistent risk assessments, no formal control-selection process or Statement of Applicability, irregular awareness training, and inconsistent third-party security checks.

## 2. My Role

For this portfolio project, I worked as a Junior Cybersecurity GRC Consultant supporting NovaPay's first ISO/IEC 27001-aligned ISMS implementation. My responsibility was to turn the case-study findings into a structured GRC workflow that management could use to understand risk, assign ownership and plan remediation.

- Understand the business environment and security expectations.
- Define a practical ISMS scope.
- Create a starter information asset inventory.
- Conduct an ISO/IEC 27001 gap assessment.
- Build a repeatable risk-assessment methodology and risk register.
- Recommend risk treatment actions and selected Annex A controls.
- Develop a selected-control Statement of Applicability.
- Create an evidence tracker and six-month PDCA implementation roadmap.

## 3. Project Objectives

The objective is not to claim that NovaPay is certified. The goal is to design a practical foundation that can move the organisation from reactive security decisions toward a defined, risk-based ISMS with clear evidence requirements.

## 4. Deliverables

| Deliverable                | Purpose                                                                                                    |
|----------------------------|------------------------------------------------------------------------------------------------------------|
| ISMS Scope                 | Defines the people, processes, information, technology and third parties governed by the ISMS.             |
| Asset Inventory            | Provides visibility of important information assets, proposed ownership, classification and criticality.   |
| Gap Analysis               | Shows confirmed weaknesses, evidence gaps, related risk and recommended improvement.                       |
| Risk Register              | Records risk statements, scores, evidence limitations, treatment actions, owners and target residual risk. |
| Risk Treatment Plan        | Tracks the response to unacceptable risks and the intended target state.                                   |
| Statement of Applicability | Documents selected Annex A controls, rationale and evidence-based implementation status.                   |
| PDCA Roadmap               | Sequences implementation, testing, internal audit, management review and continual improvement.            |
| Evidence Tracker           | Lists artifacts needed to validate that controls are designed and operating as intended.                   |

## 5. Key Improvement Introduced in this Portfolio Version

I separated confirmed findings from assumptions and evidence limitations. Where the case study did not provide proof that a control was operating effectively, I did not reduce the risk score simply because a control might exist. This makes the assessment more defensible and closer to real GRC work.